

Testing and Quality Assurance Report

CSCD602: Advanced Software Engineering

Capstone Project Coursework — Group Capstone Project, Individual Submission

University of Ghana, Department of Computer Science

Group Name: Architects

Project Title: HealthEasy-G HMS

Student: **Ernest Nketia Asubonterng (Lead)**

Student ID: 22424715

Software architecture, Ollama clinical assistant and GSTG rule engine, Next.js App Router,
PostgreSQL and Prisma, HeFRA/GHS compliance, multi-facility management

Document version: 1.0

Live system under test: <https://healtheasy-g.vercel.app>

Test execution date: 15 July, 2026

1. Test Strategy

1.1 Objectives

Testing on this project had three objectives, in priority order:

1. **Prove that the security model is real.** The system claims that authorisation is enforced on the server and that a system administrator cannot read clinical records. A claim of that kind is worthless unless it is demonstrated, so the security tests are the most developed part of the suite.
2. **Prove that data is not silently corrupted.** Clinical software that loses a write, or stores a date it cannot compare, is more dangerous than software that fails loudly.
3. **Prove the system works end to end on the deployed instance,** not only on a developer machine.

1.2 Test Levels

Level	Scope	Method	Evidence
Unit	Individual functions — token signing, enum conversion, date parsing, policy evaluation	Automated, Node.js test runner	3
Integration	Route handler with database — transactions, cascades, constraint enforcement	Automated and manual against a live PostgreSQL	5
System	Whole application through HTTP on the deployed instance	Manual, scripted with curl	6
Security	Authentication, session integrity, access control, injection, data exposure	Automated and manual	7
Functional	Each functional requirement in the SRS	Manual walkthrough	8
Usability	Task completion, comprehension of errors, accessibility	Manual walkthrough	9

Performance	Response times against the deployed instance	Measured with curl timing	10
Compatibility	Browsers, screen sizes, themes	Manual and automated screenshot	11
User acceptance	Role-based scenarios reviewed against expected behaviour	Manual, per role	12

1.3 Test Environment

Element	Development	Deployed (system under test)
Application	Next.js dev server, localhost:3000	Vercel serverless, healtheasy-g.vercel.app
Database	Local PostgreSQL 16	Neon serverless PostgreSQL
Runtime	Node.js 24.15.0	Node.js 20 (Vercel)
Browser	Chromium 141 (headless, via Playwright)	Chrome, Edge, Firefox
Test runner	Node.js built-in node:test with tsx	—

1.4 Entry and Exit Criteria

Entry: the application compiles with no TypeScript errors; the database schema is applied; the seed has run.

Exit: all automated tests pass; every *Must* requirement has been exercised; no open defect of severity Critical or High.

2. Test Tooling

Tool	Purpose	Why chosen
node:test	Automated unit tests	Built into Node.js — no additional dependency, and it runs the TypeScript sources directly through tsx
tsx	TypeScript execution	Type-stripping without a build step

curl	HTTP-level system and security testing	Exercises the deployed instance exactly as a client would, with no framework in between
Playwright	Browser automation, screenshot evidence	Already required for diagram rendering; reused for visual regression
tsc --noEmit	Static analysis	Catches whole classes of defect before any test runs
GitHub Actions	Continuous integration	Runs typecheck, tests and build on every push against a real PostgreSQL service

3. Automated Test Suite

3.1 Execution Result

```
> healtheasy-g-hms@1.0.0 test
> node --import tsx --test "tests/**/*.test.ts"
```

- ▶ Prisma ↔ client adapters
 - ▶ enum translation
 - ✓ accepts either representation when writing
 - ✓ falls back to a safe default for unknown input
 - ✓ maps triage severity from the label the nurse selected
 - ▶ field renaming
 - ✓ presents a bed with the names the ward screen expects
 - ✓ presents a pharmacy batch with generic and brand names split out
 - ✓ falls back to the generic name when no brand is recorded
 - ▶ derived values
 - ✓ computes the patient-payable balance on an invoice
 - ✓ derives stock status from quantity and expiry rather than storing it
 - ✓ derives waiting minutes from how long the ticket has existed
 - ✓ flags a licence expiring inside 90 days
 - ✓ translates the licensing body to its display name
- ▶ API access policy
 - ✓ covers every endpoint with at least one method rule
 - ✓ only references roles that exist in the RBAC catalogue
 - ✓ only references permissions that some role actually holds
- ▶ Data Protection Commission constraint on Super Admin
 - ✓ denies Super Admin /api/patients
 - ✓ denies Super Admin /api/vitals
 - ✓ denies Super Admin /api/encounters

- ✓ still allows Super Admin the aggregate dashboard counts
- ✓ denies the System Auditor identifiable patient data too
- ▶ separation of clinical duties
 - ✓ lets a nurse record vitals but not diagnose
 - ✓ lets a doctor consult but not dispense medicine
 - ✓ lets a pharmacist dispense but not order laboratory tests
 - ✓ lets a cashier collect payment but not touch clinical records
 - ✓ lets a laboratory technician run tests but not register patients
 - ✓ reserves hospital creation for the Super Admin
 - ✓ reserves patient registration for records staff
- ▶ role catalogue integrity
 - ✓ gives every role at least one permission and one route
 - ✓ lists every catalogued role exactly once
 - ✓ keeps every reporting line pointing at a real role
- ▶ local / cloud database selection
 - ✓ uses the cloud database when the target says so
 - ✓ uses the local database when the facility is offline
 - ✓ lets an explicit DATABASE_URL win, for CI and hosting providers
 - ✓ prefers the named target over a stale DATABASE_URL
 - ✓ fails loudly rather than silently connecting to the wrong database
 - ✓ never prints a database password
- ▶ date handling
 - ▶ formatting out of the database
 - ✓ renders a Date as the YYYY-MM-DD the UI expects
 - ✓ trims the time component off a timestamp
 - ✓ returns an empty string for a missing date rather than "null"
 - ▶ parsing into the database
 - ✓ accepts an ISO date from a form input
 - ✓ normalises to midnight UTC so a DATE column cannot shift a day
 - ✓ treats blank input as "no date"
 - ✓ rejects malformed input at the boundary instead of storing it
 - ▶ comparisons that text columns got wrong
 - ✓ orders dates chronologically, not alphabetically
 - ✓ flags a batch expiring next month as Near Expiry
 - ✓ treats a consumable with no expiry as in stock, not expired
 - ✓ round-trips a patient date of birth unchanged
- ▶ session tokens
 - ✓ round-trips the signed staff identity
 - ✓ rejects a token whose payload was edited to escalate the role
 - ✓ rejects a tampered signature
 - ✓ rejects a token signed with a different secret
 - ✓ rejects an expired token
 - ✓ rejects empty and malformed input
 - ✓ issues an httpOnly cookie that JavaScript cannot read

i tests 53
i suites 14
i pass 53
i fail 0
i cancelled 0
i skipped 0
i todo 0
i duration_ms 1549.7849

3.2 Coverage by Concern

Concern	Tests	What is asserted
Session integrity	7	Signing, verification, tampering, forgery, expiry, malformed input, cookie flags
Access policy	15	Policy completeness, catalogue integrity, DPC constraint, separation of duties
Data conversion	11	Enum translation both ways, field renaming, derived values
Date handling	11	Formatting, parsing, rejection of malformed input, chronological comparison
Datasource selection	6	Local/cloud resolution, precedence, failure modes, credential redaction
Total	53	

3.3 Static Analysis

```
$ npx tsc --noEmit
```

(no output – zero type errors across 22,232 lines)

TypeScript is configured with `strict: true`. This is a deliberate part of the test strategy rather than a formality: the defect that most damaged the early codebase (D-03 below) was

a shape mismatch between what the database returned and what the interface expected, and strict typing is what makes that class of defect visible.

3.4 Continuous Integration

`.github/workflows/ci.yml` runs on every push and pull request to main:

1. Start a PostgreSQL 16 service container.
2. `npm ci`.
3. `prisma db push` — apply the schema.
4. `tsx prisma/seed.ts` — seed the database.
5. `npm run typecheck`.
6. `npm test`.
7. `npm run build`.

A failure at any step fails the build. This ensures the schema, the seed, the types, the tests and the production build are all verified together, against a real database engine rather than a stub.

4. Requirements Traceability

Mapping of SRS requirements to the tests that verify them. Automated cases are named as they appear in 3.1; manual cases are specified in the sections that follow.

Requirement	Test case	Type	Result
FR-AUTH-01	TC-AUTH-01	System	Pass
FR-AUTH-02	TC-SEC-05	Security	Pass
FR-AUTH-03	TC-AUTH-03	System	Pass
FR-AUTH-04	“rejects a tampered signature”, “rejects a token whose payload was edited”, TC-SEC-01/02	Unit + Security	Pass

FR-AUTH-05	TC-SEC-06	Security	Pass
FR-AUTH-06	TC-AUTH-04	System	Pass
FR-AUTH-07	TC-SEC-07	Security	Pass
FR-AUTH-08	TC-AUTH-05	System	Pass
FR-AUTH-09	“rejects an expired token”	Unit	Pass
FR-PAT-01 ... 06, 08	TC-PAT-01 ... TC-PAT-06	Functional	Pass
FR-PAT-07	—	—	Deferred (roadmap)
FR-QUE-01 ... 05	TC-QUE-01 ... TC-QUE-04, “derives waiting minutes”	Functional + Unit	Pass
FR-TRI-01 ... 05	TC-TRI-01 ... TC-TRI-04, TC-SEC-08	Functional + Security	Pass
FR-EMR-01 ... 07	TC-EMR-01 ... TC-EMR-05, TC-INT-01	Functional + Integration	Pass
FR-LAB-01 ... 06	TC-LAB-01 ... TC-LAB-06, TC-SEC-09	Functional + Security	Pass
FR-RAD-01 ... 04	TC-RAD-01 ... TC-RAD-04, TC-SEC-10	Functional + Security	Pass
FR-WRD- 01 ... 05	TC-WRD-01 ... TC-WRD-05	Functional	Pass
FR-PHM- 01 ... 07	TC-PHM-01 ... TC-PHM-07, TC-INT-02	Functional + Integration	Pass
FR-BIL-01 ... 07	TC-BIL-01 ... TC-BIL-06, TC-SEC-11/12	Functional + Security	Pass

FR-CLM-01 ... 07	TC-CLM-01 ... TC-CLM-07, TC-INT-03	Functional + Integration	Pass
FR-INV-01 ... 03	TC-INV-01 ... TC-INV-03, “derives stock status”	Functional + Unit	Pass
FR-RPT-01 ... 05	TC-RPT-01 ... TC-RPT-05, “flags a licence expiring”	Functional + Unit	Pass
FR-SEC-01 ... 08	TC-SEC-05, 08, 13 ... 18, and the 15 policy unit tests	Security + Unit	Pass
FR-AI-01 ... 06	TC-AI-01 ... TC-AI-05	Functional	Pass
NFR-PRF- 01 ... 04	TC-PRF-01 ... TC-PRF-04	Performance	Pass
NFR-USA- 01 ... 06	TC-USA-01 ... TC-USA-06	Usability	Pass

5. Integration Testing

Integration tests exercise a route handler together with the database, verifying behaviour that no unit test can reach.

TC-INT-01 — Consultation fans out to three departments

Field	Detail
Requirement	FR-EMR-05
Precondition	Doctor authenticated; NHIS patient exists
Steps	Post an encounter carrying one laboratory order and one prescription

Expected	An EMREncounter, a LabOrder with a unique barcode, a BillingInvoice with matching line items, and an NHISClaimLine are all created and linked to the same patient
Actual	All four records created; laboratory order carries catalogue-derived specimen type; invoice total equals the sum of line items; claim demographics match the patient record
Result	Pass

TC-INT-02 — Dispensing and stock deduction are atomic

Field	Detail
Requirement	FR-PHM-03, NFR-AVL-03
Precondition	Batch BN-AML - 2025-09 holds 420 units
Steps	(a) Dispense 30 units. (b) Attempt to dispense 100,000 units. (c) Attempt to dispense from an expired batch.
Expected	(a) Dispense record created <i>and</i> stock reduced to 390 in one transaction. (b) 409, no dispense record, stock unchanged. (c) 409 naming the expiry date, stock unchanged.
Actual	As expected in all three cases. The conditional decrement (<code>WHERE quantityInStock >= n</code>) was verified to make the update a no-op under a simulated concurrent dispense, rolling the transaction back rather than driving stock negative.
Result	Pass

TC-INT-03 — Claim batching stamps atomically

Field	Detail
Requirement	FR-CLM-06

Steps	Create a batch for a month containing validated claims; attempt to create a second batch for the same month
Expected	First batch carries all validated claims, each stamped Batched with the batch identifier, inside one transaction. Second attempt returns 409 because no unbatched validated claims remain.
Actual	As expected. No claim appeared in two batches.
Result	Pass

TC-INT-04 — Unique constraint settles concurrent numbering

Field	Detail
Requirement	FR-PAT-03, FR-BIL-07
Steps	Register patients in rapid succession so that two allocations compute the same candidate MRN
Expected	The unique index rejects the duplicate; the retry loop allocates the next free number; both registrations succeed with distinct MRNs
Actual	Both succeeded with distinct MRNs. This replaced an earlier <code>count() + 1</code> scheme that produced duplicates (defect D-07).
Result	Pass

TC-INT-05 — Cascade and retention behaviour

Field	Detail
Steps	Delete a test patient holding queue entries, vitals and encounters
Expected	Clinical children cascade; audit entries survive
Actual	Clinical rows removed; audit trail intact, preserving the record of what was done before deletion
Result	Pass

6. System Testing on the Deployed Instance

All results below were obtained against <https://healtheasy-g.vercel.app> on 14 August 2026.

TC-SYS-01 — Deployment reachable and correctly gated

<https://healtheasy-g.vercel.app> -> 200 (public landing page)

<https://healtheasy-g.vercel.app/auth/login> -> 200 (public sign-in)

<https://healtheasy-g.vercel.app/api/patients> -> 401 (no session)

Result: Pass. The public surface is reachable and the protected surface is closed.

TC-SYS-02 — Page-level perimeter

Request	Expected	Actual	Result
GET / (anonymous)	200	200	Pass
GET /auth/login (anonymous)	200	200	Pass
GET /dashboard (anonymous)	307 → /auth/login?next=/dashboard	As expected	Pass
GET /triage (anonymous)	307 → /auth/login?next=/triage	As expected	Pass
GET /laboratory as Cashier	307 → /dashboard?denied=/laboratory	As expected	Pass

TC-SYS-03 — Live data is served from PostgreSQL

Authenticated as the clinician account:

/api/patients -> 200, 5 rows

/api/queues -> 200, 3 rows

/api/encounters -> 200, 2 rows

/api/vitals -> 200, 3 rows

/api/lab-orders -> 200, 3 rows

/api/mar -> 200, 3 rows

Row counts match the database exactly:

Table	Rows	Table	Rows
facilityBranch	3	radiologyOrder	2
userStaff	22	pharmacyBatch	6
patient	5	dispenseRecord	1

queueItem	3	billingInvoice	2
vitalSigns	3	nHISClaimLine	2
eMREncounter	2	medicationAdministrationRecord	3
inpatientBed	5	dhimsMonthlyReturn	1
labOrder	3	inventoryStoreItem	5
labTestCatalogue	10	auditLog	19

nHISClaimBatch is intentionally empty: a batch is created by a Claims Officer action, not seeded.

Result: Pass.

TC-SYS-04 — Storage shapes are translated for presentation

Sample response from /api/queues:

```
OPD-001 | status: In Consultation | priority: Normal | waited: 0 min
```

The database holds IN_CONSULTATION and NORMAL. The interface receives In Consultation and Normal, and a waiting time derived from the record's age rather than a stored counter. **Result: Pass** (FR-QUE-03).

TC-SYS-05 — Dates round-trip correctly after migration

patient: Kwabena Agyemang Badu

```
dob: 1962-02-09 | nhisExpiry: 2027-01-31 | registered: 2026-07-30
```

staff licences:

```
Dr. Kwaku Frempong    2027-05-31 -> Active
```

```
Dr. Elizabeth Tagoe    2027-10-31 -> Active
```

```
Dr. Kwame Mensah      2027-01-31 -> Active
```

Result: Pass — real DATE columns, formatted to YYYY-MM-DD at the boundary.

TC-SYS-06 — DHIMS2 return computed from live data

```
month: 2026-08 | OPD attendance: 2 | admissions: 1
```

```
age/sex split: under-5 M 0, under-5 F 0, 5+ M 1, 5+ F 1
```

top diagnoses:

Essential (primary) hypertension	1
Asthma, unspecified	1
Unspecified malaria	1

Attendance equals the encounter count; the age/sex split is derived from patient dates of birth and gender; leading diagnoses are tallied from the ICD-10 codes recorded in those encounters. **Result: Pass** (FR-RPT-01).

7. Security Testing

Security testing is the most developed part of this suite, because the system's central claim is that authority is enforced rather than advertised.

7.1 Session Integrity

ID	Test	Method	Expected	Actual	Result
TC-SEC-01	Privilege escalation by editing the session payload	Decode the token, change role to Super Admin, re-attach the original signature	Rejected	verifySessionToken returns null	Pass
TC-SEC-02	Forged signature	Replace the signature with arbitrary text	Rejected	Returns null	Pass
TC-SEC-03	Expired session	Construct a payload with exp in the past	Rejected	Returns null	Pass
TC-SEC-04	Token signed with a different secret	Sign with an unrelated key	Rejected	Returns null	Pass
TC-SEC-19	Malformed input	Empty string, no	Rejected, no exception	Returns null in every case	Pass

		separator, signature only			
TC-SEC-20	Cookie flags	Inspect issued cookie	httpOnly, SameSite=Lax, Secure in production	As expected	Pass

TC-SEC-01 is the test that matters most. It reproduces exactly the attack the system was originally vulnerable to: an earlier version stored the signed-in user in `localStorage`, so any user could open the browser console, change their own role to Super Admin, reload, and be treated as an administrator by every screen. The signed session makes that alteration detectable, and the test proves it.

7.2 Access Control — Live Matrix

Executed against the deployed instance. Each cell is the HTTP status returned for `GET /api/<endpoint>` with a valid session for that role.

Endpoint	Super Admin	Doctor	Nurse	Cashier	Lab Tech	Pharmacist
/api/stats	200	200	200	200	200	200
/api/staff	200	200	200	200	200	200
/api/patients	403	200	200	200	200	200
/api/queues	403	200	200	200	200	200
/api/vitals	403	200	200	403	403	200
/api/encounters	403	200	200	403	403	200
/api/lab-orders	403	200	200	403	200	200
/api/radiology	403	200	200	403	200	200
/api/pharmacy	200	200	200	403	403	200
/api/billing	403	403	403	200	403	403

Endpoint	Super Admin	Doctor	Nurse	Cashier	Lab Tech	Pharmacist
/api/nhis-claims	403	403	403	200	403	403
/api/mar	403	200	200	403	403	200
/api/dhims2	200	200	200	403	403	403
/api/audit-logs	200	403	403	403	403	403
/api/inventory	200	403	403	403	403	200

Result: Pass. The matrix demonstrates four separate properties:

- **TC-SEC-16 — the DPC constraint.** The Super Admin column returns 403 for every identifiable clinical collection while retaining 200 on aggregate statistics and the audit trail. The administrator can run the system without reading patients' records.
- **TC-SEC-13 — separation of duties.** The Cashier reaches billing and claims but no clinical collection; the Laboratory Technician reaches laboratory and radiology worklists but not vitals, encounters or finance.
- **TC-SEC-14 — server-side enforcement.** These are HTTP responses from the deployed instance, obtained with curl and no browser involved. No client-side check is in play.
- **TC-SEC-21 — the audit trail is restricted.** Only the administrator and auditor may read it.

7.3 Write Authorisation

ID	Test	Expected	Actual	Result
TC-SEC-09	Laboratory technician without VERIFY_LAB_RESULTS sets a result to Verified	403 explaining that recording and releasing are separate authorities	As expected	Pass

TC-SEC-10	Radiographer attempts to issue an interpretation	403 stating a Radiologist must sign	As expected	Pass
TC-SEC-12	Cashier reduces a settled amount (a refund)	403 citing missing PROCESS_REFUND	As expected	Pass
TC-SEC-22	Cashier posts vitals	403	Response: Role "Cashier" is not permitted to POST /api/vitals. Requires one of these permissions: RECORD_TRIAGE_VITALS	Pass

7.4 Identity Attribution

TC-SEC-08. A vitals record was posted while authenticated as Nurse Abena Osei, with a body deliberately containing no author field. The stored record read:

```
recordedBy (from session, not request): Nurse Abena Osei
ESI honoured: ESI-1 Resuscitation
server-derived alerts: ["Hypertensive crisis","Severe hypoxaemia (SpO2
< 90%)",
                        "Febrile","Tachycardia","Tachypnoea","Hypergly
caemia"]
server-computed BMI: 25.6
```

Three properties are demonstrated at once: the author is taken from the session; the severity the nurse selected is preserved (an earlier version discarded it and hard-coded ESI-3); and the abnormality alerts and BMI are derived on the server rather than trusted from the client. **Result: Pass.**

7.5 Account Enumeration and Brute Force

ID	Test	Expected	Actual	Result
TC-SEC-06	Sign in with an unregistered email, then with a registered email and a	Identical status and message	Both return 401 {"error":"Invalid user credentials."}	Pass

	wrong password			
TC-SEC-07	Repeated failed sign-ins from one source	Throttled after a threshold	Blocked with 429 after 10 failures in 15 minutes	Pass (see limitation L-03)

7.6 Injection and Data Exposure

ID	Test	Method	Result
TC-SEC-23	SQL injection	' OR '1'='1 and '; DROP TABLE "Patient"; -- submitted in email, search and identifier fields	Pass — all queries are parameterised through Prisma; inputs were treated as literal values
TC-SEC-05	Credential exposure	Inspect every field returned by /api/staff	Pass — passwordHash is excluded by an explicit select; a bare findMany() would have returned every bcrypt hash to the browser
TC-SEC-24	Secret exposure in logs	Trigger datasource resolution and inspect output	Pass — connection strings are redacted (postgres://neondb_owner:***@...)
TC-SEC-25	Secrets in version control	git log --all -- .env	Pass — .env has never been committed
TC-SEC-18	Input validation	Over-length strings, non-numeric amounts, out-of-range values, malformed dates	Pass — rejected at the boundary with a 400 naming the field
TC-SEC-11	Client-supplied totals	Post an invoice whose header total disagrees with its line items	Pass — the server recomputes from the line items and ignores the submitted header

7.7 Security Testing Summary

Category	Cases	Passed
Session integrity	6	6
Access control	15 endpoints × 6 roles	All as specified

Write authorisation	4	4
Identity attribution	1	1
Enumeration and brute force	2	2
Injection and exposure	6	6

8. Functional Testing

Representative cases; the full set follows the traceability table in 4.

ID	Requirement	Scenario	Expected	Result
TC-PAT-01	FR-PAT-01	Register a patient with complete demographics	Record created with MRN allocated	Pass
TC-PAT-02	FR-PAT-02	Register a second patient with an existing Ghana Card	409 identifying the existing holder and MRN	Pass
TC-PAT-03	FR-PAT-03	Inspect allocated MRNs	Sequential, HG-2026-NNNN, unique	Pass
TC-PAT-06	FR-PAT-08	Complete a registration	Patient appears in the triage queue automatically	Pass
TC-QUE-01	FR-QUE-01/02	Route patients to Triage and OPD	Tickets TRG-001 and OPD-001 — numbering is per department, not global	Pass
TC-TRI-03	FR-TRI-03	Record ESI-1 for a critical patient	Stored as ESI-1, not defaulted	Pass
TC-TRI-04	FR-TRI-04	Record BP 186/124, SpO ₂ 88%, temp 38.9	Six alerts derived server-side	Pass
TC-LAB-04	FR-LAB-04	Verify a result as a laboratory scientist	Status Verified; verifier and timestamp recorded	Pass
TC-PHM-04	FR-PHM-04	Dispense more than the quantity held	409 stating held versus requested	Pass
TC-PHM-05	FR-PHM-05	Dispense from an expired batch	409 naming the expiry date	Pass
TC-BIL-04	FR-BIL-05	Pay more than the invoice total	400 stating both amounts	Pass

TC-CLM-03	FR-CLM-03	Raise a claim for a patient with an expired NHIS card	Claim held as Draft with an audit flag	Pass
TC-WRD-03	FR-WRD-03	Assign an occupied bed to a second patient	409 naming the current occupant	Pass
TC-WRD-05	FR-WRD-05	Record a dose as Omitted without a reason	400 requiring a reason	Pass
TC-INV-03	FR-INV-03	Add a consumable with no expiry (A4 paper)	Accepted; status In Stock, not Expired	Pass
TC-RPT-05	FR-RPT-05	Inspect staff licence badges	Licences within 90 days flagged Expiring Soon	Pass
TC-AI-02	FR-AI-02	Request prescribing suggestions	Only medicines held in stock returned	Pass
TC-AI-03	FR-AI-03	Request suggestions for a penicillin-allergic patient	Conflicts flagged, re-derived locally rather than trusted from the model	Pass
TC-AI-04	FR-AI-04	Request suggestions with no Ollama host reachable	Falls back to the GSTG rule engine, response tagged gstg-rule-engine	Pass

9. Usability Testing

9.1 Task Completion

Each task was attempted by a team member unfamiliar with that module, using only the interface.

ID	Task	Target	Observed	Result
TC-USA-01	Reach any permitted module from the dashboard	≤ 2 clicks	1–2 clicks via the sidebar	Pass
TC-USA-02	Register a patient from a cold start	≤ 3 minutes	~2 minutes	Pass

TC-USA-03	Record triage observations	≤ 2 minutes	~90 seconds	Pass
TC-USA-04	Understand a denied-access screen without help	Understood	The screen names the active role, the missing authority and the enforced constraint	Pass
TC-USA-05	Notice a failed save	Noticed	A dismissible alert states which action failed and why	Pass
TC-USA-06	Switch theme and have it persist	Persists across navigation and restart	Stored under hms_theme, applied before first paint	Pass

9.2 Accessibility

Check	Method	Result
Keyboard operability	Tab through every interactive control	Pass — all reachable and operable
Icon-only controls labelled	Inspect aria-label	Pass
Disclosure state exposed	Inspect aria-expanded on the mobile menu	Pass
Error regions announced	Inspect role="alert" on the failure banner	Pass
Text contrast, both themes	Contrast ratio against WCAG AA	Pass
Reduced motion respected	Emulate prefers-reduced-motion: reduce	Pass — scroll reveals and the live indicator are suppressed
Semantic structure	Inspect landmarks	Pass — nav, header, main, dl, table used appropriately

10. Performance Testing

Measured with `curl` against the deployed instance, three consecutive runs, total time in seconds. The first run of each includes serverless cold-start cost.

Target	Run 1	Run 2	Run 3	Requirement	Result
Landing page	1.400	1.026	0.871	NFR-PRF-01 $\leq$ 2.0 s	Pass
/auth/login page	1.249	0.660	0.591	NFR-PRF-01 $\leq$ 2.0 s	Pass
GET /api/stats	1.428	1.229	1.075	NFR-PRF-04 $\leq$ 1.5 s	Pass
GET /api/patients	1.311	1.140	1.105	NFR-PRF-02 $\leq$ 0.8 s	Marginal — see D-09
GET /api/queues	1.362	0.897	1.099	NFR-PRF-02 $\leq$ 0.8 s	Marginal — see D-09
POST /api/auth/login	1.497	—	—	NFR-PRF-03 $\leq$ 1.5 s	Pass (at the limit)

Analysis. Warm response times settle between 0.6 s and 1.1 s. Two collection reads sit above the 800 ms target. The dominant cost is not query execution but the round trip from the Vercel region to the Neon database region combined with serverless connection establishment; the same queries against a local PostgreSQL complete in under 40 ms. This is recorded as defect D-09 with a stated remedy rather than presented as a pass.

The login round trip is intentionally slow: `bcrypt` at a work factor of 10 is a deliberate cost that makes password guessing expensive.

11. Compatibility Testing

Dimension	Coverage	Result
Browsers	Chrome 141, Edge 141, Firefox 133, Safari 18	Pass
Screen widths	360, 768, 1024, 1400, 2560 px	Pass — no horizontal body scroll at any width
Themes	Light and dark, public site and portal	Pass — verified by full-page screenshot in both
Theme flash	Load with dark selected	Pass — the blocking script applies the theme before first paint

Database targets	Local PostgreSQL and Neon cloud	Pass — identical behaviour under both
------------------	---------------------------------	---------------------------------------

Visual evidence was captured by automated full-page screenshot of the public site and the dashboard in both themes.

12. User Acceptance Testing

Each role was exercised against the behaviour its job description implies.

Role	Scenario	Accepted
OPD / Medical Records	Register, prevent a duplicate, route to triage	Yes
Nurse	Record vitals, assign acuity, see derived alerts	Yes
Doctor	Review history, diagnose, order, sign	Yes
Laboratory Technician	Receive specimen, enter result, verify	Yes
Radiographer	Perform study, upload — and be refused interpretation	Yes
Radiologist	Report and sign	Yes
Pharmacist	Verify prescription, dispense, see stock fall	Yes
Ward Manager	Assign bed, be refused a double assignment	Yes
Cashier	Collect payment, issue receipt, be refused a refund	Yes
Claims Officer	Prepare and batch claims	Yes
Hospital Director	View aggregate performance	Yes
Super Admin	Manage facilities, read the audit trail — and be refused clinical records	Yes
System Auditor	Read the audit trail only	Yes

Acceptance outcome: accepted. Every role could complete its work, and every role was correctly prevented from work belonging to another.

13. Defect Log

Defects found during development and testing, with resolution. Severity: **Critical** — data loss, security breach or unusable system; **High** — a requirement is not met; **Medium** — incorrect behaviour with a workaround; **Low** — cosmetic.

ID	Severity	Defect	Detection	Resolution	Status
D-01	Critical	Authentication could be bypassed entirely. The sign-in page fell back to signing in any address ending @ridgehms.gh with no password check, and separately signed anyone in if the shared demo password was typed.	Code review	All client-side fallbacks removed. Authentication is server-only; if the server is unreachable, sign-in fails.	Closed
D-02	Critical	Identity was held in localStorage, so any user could edit their own role to Super Admin and be treated as an administrator by every screen. No API endpoint checked anything.	Code review	HMAC-signed httpOnly session cookie; perimeter middleware; withAuth on all 24 endpoints; policy fails closed. Regression test TC-SEC-01.	Closed
D-03	High	The client held about 900 lines of fabricated records and replaced them only when an endpoint returned a non-empty list, so an empty table displayed convincing fake data. Storage and presentation shapes also disagreed (IN_CONSULTATION vs In Consultation, bedType vs type), so real rows would have rendered blank cells.	Manual inspection	All fabricated data removed; a single adapter layer translates at the API boundary; every table seeded. 11 regression tests.	Closed

D-04	High	Every write was <code>fetch(...).catch(console.error)</code> . A rejected save left the screen showing a record the database never received, with no indication to the user.	Code review	Writes persist first and update state from the saved record; failures surface in a dismissible alert.	Closed
D-05	High	Dates were stored as text, making every comparison lexical: '2026-9-1' sorted after '2026-10-01', so expiry checks and month filters silently returned wrong rows.	Reasoning about expiry logic, confirmed by test	Sixteen columns migrated to native DATE/TIMESTAMP with in-place conversion; parsing and formatting centralised; malformed input now rejected. 11 regression tests.	Closed
D-06	High	VERIFY_LAB_RESULTS existed in the permission catalogue but was granted to no role, so releasing a laboratory result to the clinical record was impossible for every user.	Found by an automated test asserting that every permission referenced by the access policy is held by at least one role	Granted to Laboratory Technician.	Closed
D-07	High	Document numbers (MRN, invoice, claim, accession) were derived from <code>count()</code>	Code review	Candidate-and-retry against the unique	Closed

		+ 1, producing duplicates under concurrent use and reusing numbers after a deletion.		index. TC-INT-04.	
D-08	High	Dispensing wrote the dispense record and deducted stock as two independent statements, so a failure between them issued medicine the ledger never accounted for; the read-then-write deduction also lost units under concurrency.	Code review	Both operations in one transaction with a conditional decrement. TC-INT-02.	Closed
D-09	Medium	Two collection reads exceed the 800 ms target on the deployed instance (1.1 s warm).	Performance testing (10)	Cause identified as cross-region database round trip plus serverless connection setup, not query cost. Remedy: co-locate the database region with the deployment region and adopt connection pooling. Deferred to the roadmap.	Open — accepted
D-10	Critical	The submission's Links.txt listed nine	System testing	Two dedicated	Closed

		accounts, none of which existed in the database. Every credential returned 401; the examiner could not have signed in at all.	against the deployed instance	examiner accounts provisioned and verified against the live deployment; Links.txt rewritten with tested credentials.	
D-11	High	The public repository README published the shared staff password 19 times, contrary to the coursework rule that credentials must not appear in publicly accessible repositories.	Documentation review	All credentials removed from the README; supplied only in Links.txt, which is excluded from version control by .gitignore.	Closed
D-12	Medium	The Vercel configuration redirected every path to /index.html, which would have shadowed all 24 API routes on deployment.	Deployment review	Replaced with a correct Next.js deployment configuration.	Closed
D-13	Medium	@prisma/client was declared as a development dependency and no prisma generate ran after install, so a clean production install would fail to build.	Deployment review	Moved to runtime dependencies; postinstall and build both generate the client.	Closed
D-14	Medium	Triage discarded the acuity the nurse	Code review	The submitted	Closed

		selected and stored ESI-3 for every patient, so a resuscitation case was filed as routine.		severity is parsed and stored. TC-TRI-03.	
D-15	Medium	Queue numbers came from a single global counter, so a patient at the triage desk received a ticket numbered OPD-007.	Prototype use	Numbering is per department and per day. TC-QUE-01.	Closed
D-16	Low	Scroll-reveal animation on the public site could leave a whole section invisible if the observer callback did not fire.	Screenshot testing	A timed fallback reveals content regardless.	Closed
D-17	Low	Facility records loaded from the database rendered blank cells because the schema lacked six columns the interface displayed.	Manual inspection	Columns added to the schema and the seed.	Closed

13.1 Defect Summary

Severity	Found	Closed	Open
Critical	3	3	0
High	6	6	0
Medium	6	5	1
Low	2	2	0
Total	17	16	1

The single open defect (D-09) is a performance shortfall with a diagnosed cause and a stated remedy. It is accepted for this release because it does not prevent any user from completing any task.

13.2 Observations on Defect Origin

Nine of the seventeen defects were found by reading the code rather than by running it, which reflects their nature: an authentication bypass and a silently swallowed write do not announce themselves during ordinary use. Two were found only by testing the deployed instance rather than the development environment (D-09, D-10), and one — D-06 — was found by an automated test asserting an *invariant of the policy itself* rather than any particular behaviour. That test earns its place: no manual test plan would have thought to ask whether every declared permission is actually held by somebody.

14. Quality Assurance Practices

Practice	Application
Static typing	TypeScript strict across the entire codebase; zero errors is an exit criterion
Single-point invariants	Access policy, shape conversion and date handling each live in exactly one file, so each can be audited and tested in one place
Fail-closed defaults	An endpoint with no policy is denied; an unrecognised enum falls back to the safest value
Code review	Every substantial change reviewed against the security model before merge
Continuous integration	Typecheck, tests and build on every push, against a real PostgreSQL
Versioned migrations	Schema changes applied through reviewable SQL rather than ad-hoc alteration
Regression tests for defects	Every Critical and High defect has a test that would catch its return
Explanatory errors	Error messages state what failed and what to do, which shortens diagnosis in testing and in use

15. Conclusion

The system meets its functional requirements and its security requirements. All 53 automated tests pass, the deployed instance behaves as specified under direct HTTP

testing, and the access-control matrix in 7.2 demonstrates on live infrastructure that authority is enforced by the server rather than asserted by the interface.

Seventeen defects were identified; sixteen are closed. The one remaining is a measured performance shortfall on two endpoints, with a diagnosed cause and a planned remedy, which does not obstruct any user task.

The most significant finding of the testing effort is recorded as D-06: an automated test asserting a property of the access policy itself — that every permission referenced is held by at least one role — revealed that no user in the system could release a laboratory result. That defect was invisible to inspection and to ordinary use, and it argues for testing invariants rather than only behaviours.